

**REPORTE CONSOLIDADO
GESTIÓN DE RIESGOS
Seguridad de la Información y Continuidad del
Negocio**

Basado en ISO/IEC 27005:2022, ISO 27001:2022 e ISO 31000:2018

Fecha de generación: 2026-02-15

1. RESUMEN EJECUTIVO

Este documento presenta el análisis integral de gestión de riesgos de seguridad de la información y continuidad del negocio, realizado siguiendo las directrices de ISO/IEC 27005:2022 e ISO 31000:2018.

Resultados Principales:

- Amenazas identificadas: 10
- Activos inventariados: 10
- Riesgos analizados: 100
- Riesgos críticos/altos: 100
- Controles ISO 27001 asignados: 30

La metodología aplicada integra la identificación de amenazas, valoración de activos según la triada CIA, análisis cuantitativo de riesgos y selección de controles del Anexo A de ISO 27001:2022.

2. AMENAZAS IDENTIFICADAS

Se identificaron 10 amenazas potenciales clasificadas según su origen y naturaleza. La distribución incluye amenazas humanas (maliciosas y no intencionales), tecnológicas, ambientales y naturales.

ID	Amenaza	Tipo	Probabilidad
A001	Ataque de Phishing	Humana - Maliciosa	4
A002	Malware/Ransomware	Tecnológica	3
A003	Acceso No Autorizado	Humana - Maliciosa	3
A004	Fallo de Hardware	Tecnológica	2
A005	Error Humano	Humana - No Intencio	4
A006	Denegación de Servicio (DoS)	Tecnológica	3
A007	Fuga de Información	Humana - Maliciosa/N	3
A008	Interrupción de Servicios Públ	Ambiental	2
A009	Desastre Natural	Natural	1
A010	Insider Threat	Humana - Maliciosa	2

3. INVENTARIO Y VALORACIÓN DE ACTIVOS

Se inventariaron 10 activos críticos valorados según la triada CIA (Confidencialidad, Integridad, Disponibilidad). La valoración permite priorizar los esfuerzos de protección según su criticidad para la organización.

ID	Activo	Tipo	Valor CIA	Criticidad
----	--------	------	-----------	------------

ACT001	Servidor de Base de Datos	Hardware	100.0%	critico
ACT002	Base de Datos de Clientes	Información	100.0%	critico
ACT003	Sistema ERP	Software	100.0%	critico
ACT004	Red Corporativa	Servicio	88.9%	alto
ACT010	Personal TI Especializado	Personas	88.9%	critico

4. ANÁLISIS DE RIESGOS

Se analizaron 100 escenarios de riesgo aplicando la fórmula: $\text{Riesgo} = \text{Probabilidad} \times \text{Impacto} \times \text{Valor CIA del Activo}$.

Distribución de riesgos:

- Críticos: 100
- Altos: 0
- Medios: 0
- Bajos: 0

ID	Activo	Amenaza	Nivel	Clasificación
R001	Servidor de Base de	Ataque de Phishing	180	Crítico
R002	Base de Datos de Cli	Ataque de Phishing	180	Crítico
R003	Sistema ERP	Ataque de Phishing	180	Crítico
R004	Red Corporativa	Ataque de Phishing	160	Crítico
R008	Sistema de Respaldos	Ataque de Phishing	160	Crítico
R010	Personal TI Especial	Ataque de Phishing	160	Crítico
R043	Sistema ERP	Error Humano	144	Crítico
R042	Base de Datos de Cli	Error Humano	144	Crítico
R041	Servidor de Base de	Error Humano	144	Crítico
R005	Correo Electrónico C	Ataque de Phishing	140	Crítico

5. CONTROLES ISO 27001 SELECCIONADOS

Se seleccionaron 30 controles del Anexo A de ISO/IEC 27001:2022 basándose en el análisis de riesgos. Los controles cubren las cuatro categorías: Organizacionales, de Personas, Físicos y Tecnológicos.

Control ID	Nombre del Control	Uso
A.5.1	Políticas de seguridad de la información	30
A.5.7	Inteligencia de amenazas	30

A.8.16	Actividades de monitoreo	30
A.8.15	Registro	30
A.8.14	Redundancia de instalaciones de procesam	30
A.8.13	Respaldo de información	30
A.6.3	Concienciación, educación y capacitación	20
A.7.13	Protección de equipos de energía	20
A.8.1	Dispositivos de punto final del usuario	20
A.8.20	Seguridad de redes	20

6. CONCLUSIONES Y RECOMENDACIONES

Conclusiones principales:

- 1. Identificación de Amenazas:** Se identificaron amenazas diversas que requieren un enfoque multicapa de seguridad, combinando controles preventivos, detectivos y correctivos.
- 2. Valoración de Activos:** Los activos críticos identificados requieren protección prioritaria debido a su alto valor para la organización y su nivel de exposición.
- 3. Análisis de Riesgos:** El análisis cuantitativo permitió priorizar eficazmente los esfuerzos de mitigación, enfocándose en los riesgos de mayor nivel.
- 4. Selección de Controles:** Los controles seleccionados del Anexo A de ISO 27001 proporcionan cobertura adecuada para los riesgos identificados.

Recomendaciones:

- Implementar un programa de concienciación en seguridad para mitigar errores humanos
- Establecer monitoreo continuo de amenazas y vulnerabilidades
- Desarrollar un plan de continuidad del negocio basado en ISO 22301
- Realizar revisiones periódicas del análisis de riesgos (al menos anualmente)
- Implementar controles en orden de prioridad según el nivel de riesgo
- Definir indicadores (KPIs) para medir la efectividad de los controles